

REPORTE DE ANÁLISIS SAST/DAST

EcoRoute — Resultados de Pruebas de Vulnerabilidades

1. INTRODUCCIÓN

1.1 Definiciones

Tipo	Definición	Herramienta en EcoRoute
SAST (Static Application Security Testing)	Análisis de vulnerabilidades en el código fuente sin ejecutarlo	bandit, semgrep, pylint (reglas de seguridad)
DAST (Dynamic Application Security Testing)	Análisis de vulnerabilidades en el sistema en ejecución	Scripts de prueba de seguridad en tiempo de ejecución, fuzzing de config.yaml

1.2 Contexto

EcoRoute no es una aplicación web, por lo que el DAST tradicional (escáner web, pruebas de inyección HTTP) no aplica directamente. El DAST se adapta al contexto de EcoRoute como pruebas de comportamiento anómalo en tiempo de ejecución: fuzzing de entradas, pruebas de condiciones de borde y verificación de manejo de errores.

2. ANÁLISIS SAST — BANDIT

2.1 Cómo Ejecutar

bash

```
bandit -r environment/ agent/ training/ evaluation/ config/ \  
-f json \  
-o results/sast/bandit_report.json \  
--severity-level low \  
--confidence-level low
```

Reporte legible en terminal

```
bandit -r environment/ agent/ training/ evaluation/ config/ \  
--severity-level medium
```

2.2 Reglas de Bandit Relevantes para EcoRoute

Código Bandit	Descripción	Módulo esperado	Severidad esperada
B301	Uso de pickle (deserialización insegura)	agent/dqn_agent.py	Medium
B302	Uso de marshal	No esperado	High
B303	Uso de MD5	No esperado	Medium
B311	Uso de random para criptografía	agent/dqn_agent.py	Low
B404	Importación de subprocess	environment/sumo_env.py	Low
B603	subprocess sin shell=True	environment/sumo_env.py	Low
B604	subprocess con shell=True	environment/sumo_env.py	High si aparece
B607	start_process_with_partial_path	environment/sumo_env.py	Medium

2.3 Resultados de Bandit

Completar tras ejecutar bandit

Código	Descripción	Módulo	Línea	Severidad	Confianza	Estado
B301	pickle usage via torch.load	agent/dqn_agent.py	—	Medium	High	Pendiente — mitigar con weights_only=True
B311	random not for security	agent/dqn_agent.py	—	Low	High	Pendiente — aceptado, no es contexto criptográfico
B404	import subprocess	environment/sumo_env.py	—	Low	High	Pendiente — aceptado, necesario para iniciar SUMO
B603	subprocess without shell	environment/sumo_env.py	—	Low	High	Pendiente — correcto, no usar shell=True

2.4 Criterios de Aceptación SAST Bandit

Criterio	Umbral	Estado
----------	--------	--------

Issues HIGH severity + HIGH confidence	0	Pendiente
Issues HIGH severity + MEDIUM confidence no justificados	0	Pendiente
Issues MEDIUM no documentados	0	Pendiente
Issues LOW documentados y aceptados	Todos con justificación escrita	Pendiente

3. ANÁLISIS SAST — SEMGREP

3.1 Cómo Instalar y Ejecutar

bash

pip install semgrep

```
semgrep --config=p/python \
  --config=p/security-audit \
  --config=p/secrets \
  environment/ agent/ training/ evaluation/ config/ \
  --json > results/sast/semgrep_report.json
```

```
semgrep --config=p/python \
  environment/ agent/ training/ evaluation/ config/
```

3.2 Reglas Semgrep Aplicadas

Conjunto de reglas	Descripción	Relevancia para EcoRoute
p/python	Reglas generales de seguridad Python	Alta
p/security-audit	Auditoría de seguridad general	Alta
p/secrets	Detección de credenciales hardcodeadas	Media — no hay credenciales esperadas
p/insecure-transport	Comunicaciones inseguras	Baja — no hay HTTP en EcoRoute

3.3 Resultados de Semgrep

Completar tras ejecutar semgrep

ID regla	Descripción	Módulo	Línea	Severidad	Estado
python.lang.security.audit.dangerous-pickle-use	Uso inseguro de pickle	agent/dqn_agent.py	—	WARNING	Pendiente — mitigar con weights_only=True
python.lang.correctness.useless-eqeq	Comparación innecesaria con == True/Falso	—	—	INFO	Pendiente
python.lang.security.audit.subprocess-shell-true	subprocesos con shell=True	—	—	ERROR	No esperado — verificar

3.4 Criterios de Aceptación SAST Semgrep

Criterio	Umbral	Estado
Reglas ERROR no justificadas	0	Pendiente
Reglas WARNING documentadas	Todas con justificación	Pendiente

4. ANÁLISIS DAST — PRUEBAS EN TIEMPO DE EJECUCIÓN

4.1 Prueba DAST-01: Fuzzing de config.yaml

Objetivo: Verificar que el sistema maneja correctamente entradas malformadas o maliciosas en el archivo de configuración sin producir comportamiento inesperado.

Casos de prueba:

ID	Entrada maliciosa	Resultado esperado	Resultado obtenido	Estado
DAST-01-A	epsilon_start: "DROP TABLE configs" (string en campo float)	ValidationError con mensaje descriptivo. Sin ejecución de código.	—	Pendiente

DAST-01-B	learning_rate: -999.0 (valor negativo fuera de rango)	ValidationError indicando que lr debe ser positivo	—	Pendiente
DAST-01-C	n_episodes: 999999999 (valor extremadamente alto)	Warning de duración estimada. Sistema no bloquea.	—	Pendiente
DAST-01-D	sumo_config_path: ".././../etc/passwd" (path traversal)	Error de archivo no encontrado. Sin acceso a rutas fuera del proyecto.	—	Pendiente
DAST-01-E	seed: null (semilla nula)	Uso de semilla por defecto o error descriptivo	—	Pendiente
DAST-01-F	emission_model: "INVALID_MODEL" (valor no permitido)	ValidationError indicando valores válidos: VSP o COPERT	—	Pendiente
DAST-01-G	Config YAML con referencias circulares (&anchor y *alias)	Sistema carga sin bucle infinito o lanza error controlado	—	Pendiente
DAST-01-H	Config YAML con caracteres especiales en strings: ; rm -rf /	Tratado como string literal. Sin ejecución de comandos.	—	Pendiente

Comando para ejecutar fuzzing:

bash

pytest tests/test_security.py::test_config_fuzzing -v

4.2 Prueba DAST-02: Prueba de Path Traversal en Rutas de Archivos

Objetivo: Verificar que el sistema no accede a archivos fuera del directorio del proyecto cuando se le pasan rutas maliciosas.

ID	Ruta maliciosa	Componente probado	Resultado esperado	Estado
DAST-02-A	.././../etc/passwd en sumo_config_path	SumoEnv	FileNotFoundError o ValidationError. Sin lectura de /etc/passwd.	Pendiente

DAS T-02-B	../../../../home/user/.ssh/id_rsa en checkpoint_path	DQNAgent.load_checkpoint()	FileNotFoundError. Sin lectura del archivo SSH.	Pendiente
DAS T-02-C	/absolute/path/outside/project en cualquier ruta	ConfigLoader	Error descriptivo. Sin acceso a rutas absolutas externas.	Pendiente
DAS T-02-D	results/../../../../config/config.yaml en export path	Logger	Ruta normalizada al directorio results/. Sin escritura fuera de results/.	Pendiente

4.3 Prueba DAST-03: Prueba de Checkpoint Malicioso

Objetivo: Verificar que cargar un checkpoint .pth malicioso no ejecuta código arbitrario.

ID	Checkpoint malicioso	Resultado esperado	Estado
DAST-03-A	Archivo .pth con payload pickle que ejecuta os.system('echo PWNED')	Con weights_only=True: UnpicklingError o error controlado. Sin ejecución del comando.	Pendiente
DAST-03-B	Archivo .pth con estructura de pesos de dimensión incorrecta	RuntimeError de PyTorch indicando incompatibilidad de dimensiones. Sin crash no manejado.	Pendiente
DAST-03-C	Archivo .pth vacío o corrupto	Error descriptivo de carga. Sin crash del proceso principal.	Pendiente
DAST-03-D	Archivo .pth con hash SHA-256 incorrecto	HashVerificationError antes de llamar torch.load(). Sin carga del archivo.	Pendiente

4.4 Prueba DAST-04: Prueba de Agotamiento de Recursos

Objetivo: Verificar que el sistema no colapsa ante condiciones de uso extremo de recursos.

ID	Condición	Resultado esperado	Estado
DAST-04-A	replay_buffer_capacity: 10000000 (10M transiciones)	ConfigLoader rechaza el valor con ValidationError. Límite máximo respetado.	Pendiente

DAST-04-B	max_steps_per_episode no definido en config.yaml	Sistema usa valor por defecto o lanza ConfigError. Sin bucle infinito.	Pendiente
DAST-04-C	n_episodes: 0 (cero episodios)	Sistema lanza ValidationError. Sin ejecución de loop vacío.	Pendiente
DAST-04-D	batch_size mayor que replay_buffer_capacity	ValidationError indicando inconsistencia. Sin crash en train_step().	Pendiente

4.5 Prueba DAST-05: Prueba de Inyección en Proceso SUMO

Objetivo: Verificar que los parámetros pasados al proceso SUMO no permiten inyección de comandos.

ID	Input malicioso	Resultado esperado	Estado
DAST-05-A	sumo_config_path: valid.sumocfg; rm -rf /tmp/test	La ruta es tratada como string literal. SUMO falla al no encontrar el archivo. Sin ejecución de rm.	Pendiente
DAST-05-B	sumo_config_path: valid.sumocfg && calc.exe	Igual que DAST-05-A. Sin ejecución de calc.exe.	Pendiente
DAST-05-C	Puerto TraCI: string en lugar de entero	TypeError o ValidationError. Sin inicio de SUMO.	Pendiente

5. RESUMEN EJECUTIVO DE VULNERABILIDADES

5.1 Vulnerabilidades Identificadas

ID	Herramienta	Descripción	Severidad	Estado de mitigación
VULN-01	Bandit B301 + DAST-03	Deserialización insegura de checkpoint .pth via pickle	Medium	Mitigar: weights_only=True + hash SHA-256
VULN-02	Semgrep + DAST-02	Falta de validación de path traversal en rutas de archivos	Medium	Mitigar: pathlib + validación de ruta dentro del proyecto
VULN-03	DAST-01	Falta de validación de tipos en parámetros de config.yaml	Low-Medium	Mitigado parcialmente: ConfigLoader.validate()

VULN-04	DAST-04	Sin límite máximo en replay_buffer_capacity	Low	Mitigar: límite en ConfigLoader.validate()
VULN-05	DAST-05	Parámetros de SUMO no sanitizados antes de subprocess	Low	Mitigar: pathlib.Path + lista de argumentos sin shell
VULN-06	Bandit B311	Uso de random no criptográfico en epsilon-greedy	Low	Aceptado: no es contexto criptográfico
VULN-07	THR-I-02	Riesgo de exponer resultados en repositorio Git	Low	Mitigado: .gitignore configurado

5.2 Estado General de Seguridad

Categoría	Vulnerabilidades críticas	Vulnerabilidades altas	Vulnerabilidades medias	Vulnerabilidades bajas
SAST (Bandit)	0	0	1 (VULN-01)	2 (VULN-06, VULN-03)
SAST (Semgrep)	0	0	1 (VULN-02)	0
DAST	0	0	1 (VULN-03)	3 (VULN-04, VULN-05, VULN-07)
TOTAL	0	0	3	5

5.3 Plan de Remediación

ID Vulnerabilidad	Acción de remediación	Responsable	Sprint objetivo	Estado
VULN-01	Implementar torch.load(path, weights_only=True) y verificación SHA-256 en DQNAgent.load_checkpoint()	Desarrollador	Sprint 3	Pendiente
VULN-02	Implementar validación de ruta con pathlib.Path.resolve() y verificar que la ruta está dentro del directorio del proyecto	Desarrollador	Sprint 2	Pendiente

VULN-03	Completar validación de tipos con pydantic en ConfigLoader para todos los parámetros	Desarrollador	Sprint 1	Pendiente
VULN-04	Agregar límite máximo de replay_buffer_capacity = 100.000 en ConfigLoader.validate()	Desarrollador	Sprint 3	Pendiente
VULN-05	Reemplazar string en subprocess por lista de argumentos. Validar sumo_config_path con pathlib antes de pasarlo	Desarrollador	Sprint 2	Pendiente
VULN-06	Documentar como riesgo aceptado en este reporte. No requiere cambio de código.	Analista	Sprint 1	Aceptado
VULN-07	Verificar .gitignore en cada PR. Agregar hook pre-commit de verificación	Desarrollador	Sprint 1	Pendiente

6. CRITERIO DE ACEPTACIÓN GLOBAL DE SEGURIDAD

El sistema supera el Security Gate cuando cumple todos los criterios:

Criterio	Herramienta	Umbral	Estado
Vulnerabilidades críticas	SAST + DAST	0	Pendiente
Vulnerabilidades altas no mitigadas	SAST + DAST	0	Pendiente
Vulnerabilidades medias no documentadas	SAST + DAST	0	Pendiente
torch.load con weights_only=True	Revisión de código	Implementado	Pendiente
subprocess sin shell=True	Bandit B604 = 0	0 instancias	Pendiente
Path traversal mitigado	DAST-02	Todos los casos pasan	Pendiente
Checkpoint malicioso sin ejecución de código	DAST-03-A	Pasa sin ejecución	Pendiente
.gitignore cubre results/ y checkpoints/	Revisión manual	Verificado	Pendiente